Simulazione di Spear Phishing e IA Avversariale

1. Sintesi

Si parte da una notizia reale e recente, la richiesta dei Democratici al Congresso di conservare i documenti in vista di indagini, e il mittente è un profilo istituzionale scelto tramite un accurata analisi degli enti publici Americani.

2. Introduzione e obiettivi

Lo spear phishing dovrebbe risultare efficace perché il pretesto è costruito su informazioni reali

Individuare, con un ragionamento replicabile, il mittente più verosimile per il contesto scelto.
Mostrare una tesla in fiamme per provocare almeno un po'di sgomento aggiungendo la parte comica del meme Zoe Roth Disaster Girl.

3. Il pretesto e la scelta del mittente

3.1 La notizia reale

Negli Stati Uniti, dopo le elezioni di metà mandato, i Democratici assumono il controllo del Congresso a partire da gennaio 2027 e più commissioni hanno chiesto all'amministrazione, a Donald Trump e a Elon Musk di conservare tutti i documenti in vista di indagini.

3.2 Come ho individuato il mittente

Per identificare quale potesse essere la mail di Elon Musk mi sono affidato a Maltego trovando svariate mail.



Per queste ragioni ho scelto la mail elon@tesla.com che mi è parsala più probabile per comunicazioni di questo tipo dopo aver fatto delle ricerche sul portale fingerprint.to .

4. La catena dell'attacco

4.1 Il mittente scelto

House Oversight Committee, con riferimento al presidente entrante Robert García. È la massima autorità legata alla richiesta di conservazione documentale(il dominio mostrato è volutamente simile, ma diverso, da quello ufficiale oversight.house.gov.)

Da: House Oversight Committee <records@oversight.house-gov-verify.com>
A: elon@tesla.com

Oggetto: RE: Federal Records Act: conferma di conservazione documentale entro il 18 novembre

A chi di competenza,

Ai sensi del Federal Records Act e in relazione alle richieste di conservazione documentale inoltrate dal presidente della Commissione Oversight, Robert García, le chiediamo di confermare la ricezione e di caricare l'attestazione di conservazione dei documenti entro il 18 novembre 2026.

Per evitare le sanzioni previste dalla normativa federale, acceda al Portale Sicuro della Commissione e inserisca le sue credenziali aziendali per firmare l'attestazione:

https://oversight.house.gov/secure/acknowledge

La mancata conferma entro il termine sarà annotata come non-conformità e riferita alla Commissione.

Cordiali saluti,
Ufficio del Presidente
Commissione Oversight, Camera dei Rappresentanti

Destinazione del link (simulata)



4.4 I principi di persuasione di Cialdini

Principio	Come viene sfruttato	Passaggio
Autorità	Mittente «House Oversight Committee», riferimento al presidente Robert García e al Federal Records Act.	«Ai sensi del Federal Records Act… presidente della Commissione Oversight, Robert García…»
Scarsità / Urgenza	Scadenza reale (18 novembre), minaccia di sanzioni e annotazione di non-conformità.	«…sanzioni… entro il 18 novembre 2026… sarà annotata come non-conformità.»
Coerenza / Impegno	«Confermare la ricezione» e «firmare l'attestazione» presentano la risposta come l'atto coerente con l'obbligo legale.	«…confermare la ricezione… per firmare l'attestazione.»
Prova sociale	La domanda è presentata come inoltrata a più destinatari, condizione condivisa e non evento isolato.	«…richieste di conservazione documentale inoltrate…»
Identità condivisa	L'accesso è riservato ai destinatari, gruppo esclusivo di cui il bersaglio fa parte.	«Accesso riservato ai destinatari della richiesta.»

5. Red flag e indicatori di compromissione

Dominio usurpato: oversight.house-gov-verify.com al posto del dominio ufficiale oversight.house.gov.
Link mascherato: il testo del link mostra oversight.house.gov ma la destinazione reale è diversa .
Urgenza indotta: scadenza e minaccia penale mirano a inibire la verifica fuori banda.
Mittente non autenticato: assenza di firma SPF, DKIM e DMARC riconducibile al dominio governativo ufficiale.

6. Contromisure e buone pratiche

Controllo del dominio: confrontare il dominio del mittente e del link con quello ufficiale prima di fare clic.
Anti-impersonation e analisi dei link: segnalazione dei domini simili e ispezione degli URL in ingresso.

7. Conclusioni

La simulazione mostra l'intera catena dello spear phishing: una notizia reale, un mittente istituzionale , un link mascherato. Quasi ogni principio di Cialdini trova una collocazione precisa nella comunicazione. La contromisura più efficace resta la verifica del dominio reale, non la fiducia nell'autorità o nell'urgenza percepita.